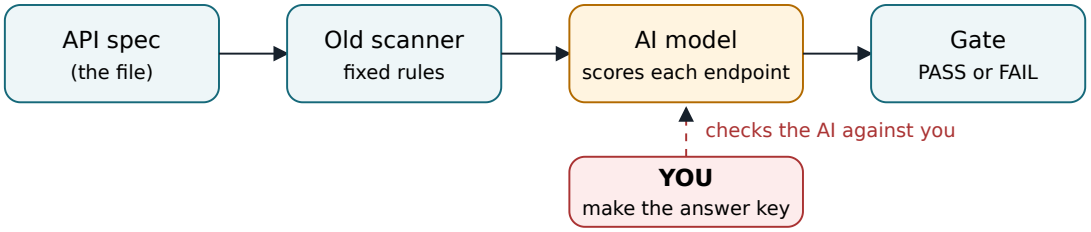
APIGUARD: Hand-Labelling Task

Final-year project, CSS453. Please read this page, then start. Time needed: about 3 to 4 hours (pilot ~30 min).

1. What is this project?

Every API has a file (an **OpenAPI spec**) that lists its **endpoints**. An endpoint is one address, like `DELETE /users/5`. Some endpoints are risky, for example a delete that needs no login. Our tool, **APIGUARD**, reads the spec and gives every endpoint a **risk score**.



> **Why we need you:** to know if the AI is really good, we must compare it with correct answers made by people. Two people (you and your partner) label the same endpoints **separately**. If you mostly agree, the answer key is trustworthy.

2. Your task

You get two files. Each row is **one endpoint**:

- `L2_pilot_sheet.csv`: 32 rows. Do this **first**.
- `L2_main_sheet.csv`: 304 rows. Do this **after** the pilot discussion.

For each row ask: "Can I see a security problem from this row alone?" → type 1 (yes) or 0 (no).

3. How to decide

Put 1 if you see...	Category (write for 1s only)
`security_requirement` says **NONE** on a write (POST, PUT, PATCH, DELETE). Anyone can change or delete data.	API2 or API5
NONE on a read that returns private data (emails, users, payments, medical, secrets).	API2 or API3
The **only** credential is a secret **in the URL**: a *required* `api_key (query)` or `token (query)` on a spec with no other login.	API2
The response lists passwords, tokens, or many personal fields.	API3
A path like `/users/{id}` with nothing that checks who you are (you could read someone else's data).	API1

An admin-style action (suspend user, delete team) that a normal user could call.	API5
A big list with no limit or paging options (someone could overload it).	API4
Old or test endpoints left open, or a plain `http` server.	API8 or API9

Put 0 if...
The endpoint has a login (apiKey, oauth2, http basic or bearer) and nothing else looks wrong.
An *optional* `access_token (query)` next to **oauth2**. Many Google specs list it on every endpoint; it is normal, so do **not** count it.
The data is clearly public (trivia, bus times, weather, a public catalogue).
You cannot tell from the row. Pick your best guess and write why in `notes`.

4. Rules (important)

1. **Work alone.** Do not talk or compare until you have both finished the pilot.
2. Judge **only from the row**. Do not search the API online.
3. Do **not** use any scanner output or AI score. If anyone sent you a file with `KEY` in its name, do not open it.
4. Do not change the `sample_id` or reorder the rows.

5. Which columns to fill

Column	What to type
`label_A_0or1` (Person A) or `label_B_0or1` (Person B)	1 = security problem visible, 0 = not. **Only fill your own columns.**
`category_A` / `category_B`	For 1s only: API1 to API10, separated by `;`, e.g. `API2;API5`
`notes`	Optional. Write a few words if you were unsure.

Worked examples (made-up rows, not in your sheet):

Row	Label	Why
`DELETE /v1/orders/{id}`, security **NONE**	**1** (API2;API5)	A delete with no login.
`GET /weather/today`, security **apiKey**, response: temperature	**0**	Public data and it has a login.
`GET /users`, security **NONE**, response: email, phone	**1** (API2;API3)	Personal data with no login.
`POST /payments`, security **oauth2**	**0**	Has a login; nothing else visible.

6. Steps and how to save

1. Open the sheet in Excel. If Thai or special characters look wrong, use Data → From Text/CSV and choose UTF-8.
2. Make a copy first. Name yours `L2_pilot_A.csv` and `L2_main_A.csv` (Person B uses `_B`).
3. Do the **pilot (32 rows)**. Save as **CSV UTF-8**. Tell your partner you are done, then compare. Talk about the rows you differ on and agree on the rules.
4. Do the **main sheet (304 rows)** alone. Do not copy from your partner or from the pilot discussion notes.
5. Send both of your CSV files back to Varit.

> Tip: you are not expected to be perfect. We measure how much you agree (Cohen's κ, target 0.6 or more). If you differ a lot, we improve the rules together.